Cybersecurity Daily Newsletter

Vol. 007 | 2026-11-12 09:00 WIB

Top 5 Highlights

• Hackers stole AI credentials to get $740,000 in free compute; Railway picked up the bill

• ISC Stormcast For Thursday, November 12th, 2026
https://isc.sans.edu/podcastdetail/10176, (Thu, Nov 12th)

• Chinese AI Project Scouts Spies in Taiwan Chip Industry

• Japan Pushes Emergency Funding for Cybersecurity as AI-Assisted Breaches Rise

• Google releases open-source agent substrate for secure AI sandboxing

Threat Intelligence (10)

01. ISC Stormcast For Thursday, November 12th, 2026 https://isc.sans.edu/podcastdetail/10176, (Thu, Nov 12th)

ISC Stormcast For Thursday, November 12th, 2026 https://isc.sans.edu/podcastdetail/10176, (Thu, Nov 12th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://isc.sans.edu/diary/rss/33512

02. Active ScreenConnect attacks breach MSPs, impact dozens of organizations

ConnectWise is investigating an active malware campaign targeting managed service providers (MSPs) that uses compromised ScreenConnect environments to deploy rogue remote-access clients to customer devices. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.bleepingcomputer.com/news/security/active-screenconnect-attacks-breach-msps-impact-dozens-of-organizations/

03. Suspected Chinese Malware Supplier Tied to Three Hacking Campaigns

Check Point links three China-nexus clusters through a shared Sparrow malware framework

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.infosecurity-magazine.com/news/chinese-malware-tied-three-hacking/

04. AntiFox AI Pentesting Platform Linked to Attacks That Accessed AWS Production Secrets

Cybersecurity researchers have disclosed details of a campaign in which an emerging agentic penetration testing platform called AntiFox has been used to steal Amazon Web Services (AWS) credentials and pivot laterally into compromised environments. "In several recently observed intrusions, Alibaba Cloud systems hosting AntiFox interfaces were associated with...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/11/antifox-ai-pentesting-platform-linked.html

05. Remus malware claims Gmail access even after you change your password

Developers of the infostealer Remus claim their malware can retain access to a victim’s Gmail even after a password reset.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.malwarebytes.com/blog/news/2026/11/remus-malware-claims-gmail-access-even-after-you-change-your-password

06. Microsoft researchers demonstrate hidden backdoor technique for AI agents

Microsoft researchers have demonstrated how small changes to an AI model can implant a hidden backdoor, causing an agent to execute an attacker’s command when a specific trigger appears. The technique, called Lazarus, requires no model retraining and allows the agent to behave normally during standard safety evaluations. The company has not observed threat…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://www.helpnetsecurity.com/2026/11/11/microsoft-hidden-ai-backdoors-lazarus/

07. [+24h Old] Microsoft Researchers Show AI Agents Can Be Backdoored by Editing Fewer Than 10 Neurons

An AI model can be given a hidden backdoor by editing fewer than 10 of its rarely used neurons, without retraining the model, Microsoft researchers have shown. When a chosen trigger appears, the model outputs an attacker's command, which an agent using that model would run with the agent's own permissions. The attacker must be able to change the model's wei…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/11/microsoft-researchers-show-ai-agents.html

08. [+24h Old] New malware doesn’t call home, it turns your Exchange server into its home

There’s a new flavor of cereal on the table, but not the appealing kind, particularly for defenders. A new report from global security company ESET describes a “sophisticated,

modular, and tightly interconnected” toolset designed to run on compromised Exchange servers for long-term cyberespionage. The malware is named ‘Cereal’ because it relies heavily on s…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: https://www.csoonline.com/article/4247162/new-malware-doesnt-call-home-it-turns-your-exchange-server-into-its-home.html

09. [+24h Old] ISC Stormcast For Wednesday, November 11th, 2026 https://isc.sans.edu/podcastdetail/10174, (Wed, Nov 11th)

ISC Stormcast For Wednesday, November 11th, 2026
https://isc.sans.edu/podcastdetail/10174, (Wed, Nov 11th)

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://isc.sans.edu/diary/rss/33510

10. [+24h Old] Three China-Nexus Espionage Campaigns Linked Through Sparrow Malware Ecosystem

Three distinct threat activity clusters with shared infrastructure and malware code similarities have been observed targeting telecommunications providers, government organizations, military entities, research institutions, and critical infrastructure across Latin America, Asia, and Europe over the past year. Check Point Research is tracking the clusters un…

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: https://thehackernews.com/2026/11/three-china-nexus-espionage-campaigns.html

Latest Vulnerabilities (10)

01. Hackers stole AI credentials to get $740,000 in free compute; Railway picked up the bill

As AI model training and distillation increase, AI tokens are becoming a piping hot currency for threat actors. Cloud hosting provider Railway found out the hard way; it has confirmed a near 26-hour battle against attackers targeting AI provider credentials to sell to AI ‘transfer stations’ for use in model distillation. The crooks generated about $740,000…

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.csoonline.com/article/4247578/hackers-stole-ai-credentials-to-get-740000-in-free-compute-railway-picked-up-the-bill.html

02. Chinese AI Project Scouts Spies in Taiwan Chip Industry

The CCP built a Big Data system to scrape reams of information and learn about individuals abroad, to potentially target and exploit them. Think Alice Huang Lite.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/threat-intelligence/chinese-ai-project-scouts-spies-taiwan-chip-industry

03. Google releases open-source agent substrate for secure AI sandboxing

As reported by Silicon Angle, Google LLC has introduced Agent Substrate, an open-source project designed to provide secure, efficient sandboxing for autonomous AI agents.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/google-releases-open-source-agent-substrate-for-secure-ai-sandboxing

04. CISA adds IBM, SignalWire, OpenSSH and GPUStack flaws to known exploited vulnerabilities catalog

Coverage from Security Affairs indicates that the Cybersecurity and Infrastructure Security Agency has added four critical vulnerabilities to its Known Exploited Vulnerabilities catalog.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/cisa-adds-ibm-signalwire-openssh-and-gpustack-flaws-to-known-exploited-vulnerabilities-catalog

05. Baker Tilly notifies clients of data breach at third-party provider

The Baker Tilly Advisory Group is notifying clients that a data breach has compromised certain personal information about them and their dependents. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.bleepingcomputer.com/news/security/baker-tilly-notifies-clients-of-data-breach-at-third-party-provider/

06. Attackers leverage AntiFox platform on Alibaba cloud to target aws environments

Following insights from Bleeping Computer, security researchers have identified a growing trend of attackers utilizing Alibaba Cloud to host self-managed instances of AntiFox, an open-source agentic penetration testing platform, to compromise web services and Amazon Web Services environments.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/brief/attackers-leverage-antifox-platform-on-alibaba-cloud-to-target-aws-environments

07. N-able Takes N-central Platform Offline After Discovery of 33 Flaws

The RMM provider also released a hotfix as one of recommended mitigations to address public exploits for the alleged zero-days that allow for attacker takeover.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.darkreading.com/endpoint-security/n-able-n-central-offline-33-flaws

08. Cisco BroadWorks flaw added to CISA's exploited vulnerabilities list

CISA confirms active exploitation of a Cisco BroadWorks flaw exposing sensitive telecom files.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.scworld.com/news/cisco-broadworks-flaw-added-to-cisas-exploited-vulnerabilities-list

09. The global socket: how threat actors are weaponizing GSocket for stealthy C2

Threat actors are deploying GSocket on compromised Linux servers to keep encrypted remote access after the original vulnerability is patched. Learn how to detect, investigate, and remediate this activity. The post The global socket: how threat actors are weaponizing GSocket for stealthy C2 appeared first on Microsoft Security Blog .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://www.microsoft.com/en-us/security/blog/2026/11/11/global-socket-how-threat-actors-weaponizing-gsocket-stealthy-c2/

10. Microsoft Patch Tuesday November 2026, (Tue, Nov 10th)

Microsoft continues its AI-induced patch surge, addressing 1,260 different vulnerabilities this month. 68 of these vulnerabilities are considered critical. 167 of the vulnerabilities are Chromium issues affecting Microsoft Edge.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: https://isc.sans.edu/diary/rss/33508

Data Breach & Cybercrime (10)

01. Japan Pushes Emergency Funding for Cybersecurity as AI-Assisted Breaches Rise

The package adds public-private cyber responders, an AI-focused team run by the economic ministry, and more leeway to use the government's new active cyber-defense powers.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.darkreading.com/cybersecurity-operations/japan-emergency-funding-cybersecurity-ai-assisted-breaches

02. Researchers link Qilin ransomware administrator to St. Petersburg man

Per Krebs on Security, the cybercrime group Qilin has become the most active ransomware-as-a-service operation, with researchers identifying the group's administrator as a 36-year-old man residing in St. Petersburg, Russia.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.scworld.com/brief/researchers-link-qilin-ransomware-administrator-to-st-petersburg-man

03. Japan faces rising cybersecurity threats to its national ID infrastructure

Japan is grappling with a significant increase in data breaches targeting the ecosystem surrounding its My Number national identification system, according to a recent report by Biometric Update.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.scworld.com/brief/japan-faces-rising-cybersecurity-threats-to-its-national-id-infrastructure

04. Notion says Fireworks breach exposed customer AI chat transcripts

Notion, the digital workspace platform, disclosed that a security breach at its AI infrastructure provider, Fireworks AI, exposed Notion AI chat transcripts in a small number of workspaces. […]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.bleepingcomputer.com/news/security/notion-says-fireworks-breach-exposed-customer-ai-chat-transcripts/

05. Vanderbilt restores systems after cyberattack as hackers claim data theft

Vanderbilt University is restoring campus technology, but has not confirmed the attackers’ claims of stolen student and employee data.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.malwarebytes.com/blog/news/2026/11/vanderbilt-restores-systems-after-cyberattack-as-hackers-claim-data-theft

06. Who Runs the Ransomware Group Qilin?

The cybercrime group Qilin has emerged as the world's most active ransomware affiliate program, claiming at least 365 victim organizations in the past three months alone. But even top Russian hackers make operational security mistakes, and the administrator of Qilin has made a few key missteps over the last decade that all point to a 36-year-old man living…

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://krebsonsecurity.com/2026/11/who-runs-the-ransomware-group-qilin/

07. Maersk confirms data breach as WhiteArmor ransomware demands $5 million

Maersk announced that a threat actor gained unauthorized access to a local legacy system inherited through an earlier acquisition and extracted data from it. [...]

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://www.bleepingcomputer.com/news/security/maersk-confirms-data-breach-as-whitearmor-ransomware-demands-5-million/

08. Over 35,000 Grok-Built Apps Exposed Online, Some Leaking Confidential Data and Passwords

Of the 37,571 Grok-built apps that security company Claroc found online, 35,578 were open to anyone without a sign-in, the researchers said yesterday. They included 24 apps built by staff at the social network X and at SpaceXSI, the company that makes the Grok AI assistant. Most of the open apps were games, landing pages, and calculators, but about 1 in 10…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://thehackernews.com/2026/11/over-35000-grok-built-apps-exposed.html

09. Citrus Ransomware: VLESS for traffic, Sn00py for encryption, and LLMs lending a hand

We break down the Citrus Ransomware group's attacks: the attackers' TTPs and tooling, including VLESS traffic tunneling and LLM use, plus their links to Toy Ghouls.

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: https://securelist.com/citrus-ransomware/121879/

10. [+24h Old] Fingerprint trains specialized models to detect distinct fraud types

Fingerprint has launched Fraud Score, a predictive fraud signal trained directly on customers’ own fraud outcomes and powered by Fingerprint’s device intelligence and machine learning models. Fraud Score learns the fraud types at each organization to help them identify fraud more accurately without having to build and maintain their own models. Basic risk s…

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: https://www.helpnetsecurity.com/2026/11/11/fingerprint-fraud-score/